Risk And Controls

Segregation of Duties (SOD) Training

In this training, we will discuss....

- What is Segregation of Duties (SOD)
- Steps to perform an SOD assessment
- How to document SOD assessment results using the SOD template

INTRODUCTION TO SEGREGATION OF DUTIES (SOD)

1

What is SOD?

Segregation of duties (SOD) is an internal control designed to minimize error and fraud by ensuring that at least two individuals are responsible for the separate parts of any business activity.

In Risk Control Matrix, the SOD requirement is clearly specified in the control guideline of the relevant controls.

Example: APA05.1 Purchase pre-authorization

- A Control Owner is an individual independent from the requester, with the appropriate authority level as defined by the local authority matrices.

2

What is SOD of the user permission in IT application?

Application control can be configured in IT application to ensure that the same person cannot initiate, approve and record the transactions at the same time to mitigate the risk arising from SOD conflicts.

Example: SOD_APA1 Access to create or edit purchase pre-authorization data should be segregated from access to pre-approve the purchase.

- A user who has access to create or edit purchase pre-authorization should not be granted access to approve the purchase pre-authorization in IT application.

INTRODUCTION TO SOD RULESET

In Risk Control Matrix, there are several SOD rulesets for key business processes in CEN31 controls of Control Environment. The SOD rulesets refer to SOD of access controls in IT applications.

The following table shows SOD rulesets for Procure to Pay activities.

SOD_APA1	Access to create or edit purchase pre-authorization data should be segregated from access to pre-approve the purchase.
SOD_APA2	Access to create or edit purchase pre-authorization data should be segregated from access to edit vendor master file.
SOD_APA3	Access to pre-approve purchase should be segregated from access to vendor invoice entry.
SOD_APA4	Access to create, edit, or approve payment should be segregated from access to edit vendor master file.
SOD_APA5	Access to create or edit payment should be segregated from access to approve payment.
SOD_APA6	Access to create or edit or approve payment should be segregated from access to approve three way / two-way match.
SOD_APA7	Access to create or edit or approve invoice data should be segregated from access to edit vendor master file.
SOD_APA8	Access to request new vendors/ vendor changes should be segregated from access to approve new vendors/ vendor changes.

SEGREGATION OF DUTIES (SOD) ASSESSMENT PROCEDURES ON SOD RULESETS

Step 1 Is IT application used to process the transactions?

START



YES **Assess whether SOD conflicts on the user permission in IT application exist**

- Obtain user permission report for the IT application (subject to IUC procedures)
- Use SOD template to document the SOD assessment results



END

NO **Document the rationale**

- Assessment on the SOD rulesets is not required as the transactions are not processed in IT application. Document the rationale for not performing the SOD assessment on SOD ruleset.

Step 2 Is there any SOD conflict?



YES **SOD conflict identified**

- Evaluate whether the user permission with SOD conflict can be removed



END

NO **No SOD conflict identified**

- Document approval of the SOD assessment

Step 3 Can the access be removed?



END

YES **Remove user permission**

- Retain evidence of completion i.e., removal of the user permission
- Assess impact of SOD conflict before user permission removal by generating activity report for the individual to determine if any inappropriate transaction was processed



END

NO **Retain user permission**

- Document the rationale
- Design and implement a detective control as a key financial control in the local version of Risk Control Matrix (RCM)
- Determine whether an impact assessment is needed for an interim period

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET



SOD Conflict on User Permissions – Key Points to Remember

1. SOD conflict on the user permissions may be retained but the risk needs to be mitigated.

2. For the identified SOD conflict, a detective control must be documented as a key financial control in the local version of Risk and Control Matrix (RCM) to minimize the risk of errors or irregularities.
   - For example, get another person to review the journal entries created and posted by the same person.

3. Determine whether an impact assessment is needed for an interim period:
   - Assess whether if any inappropriate transaction was processed before the SOD conflict was identified
   - Evaluate effectiveness of the detective control in minimizing the risk arising from the SOD conflict to an appropriate level.
   - Consider whether the user permissions can be properly segregated in the future

KNOWLEDGE CHECK

True or False:

By having SOD, it minimizes the opportunities for the employee to commit fraud, and errors may also be more easily identified if the transaction is reviewed by another pair of eyes.



The SOD rulesets in CEN controls refer to SOD of access controls in IT applications.



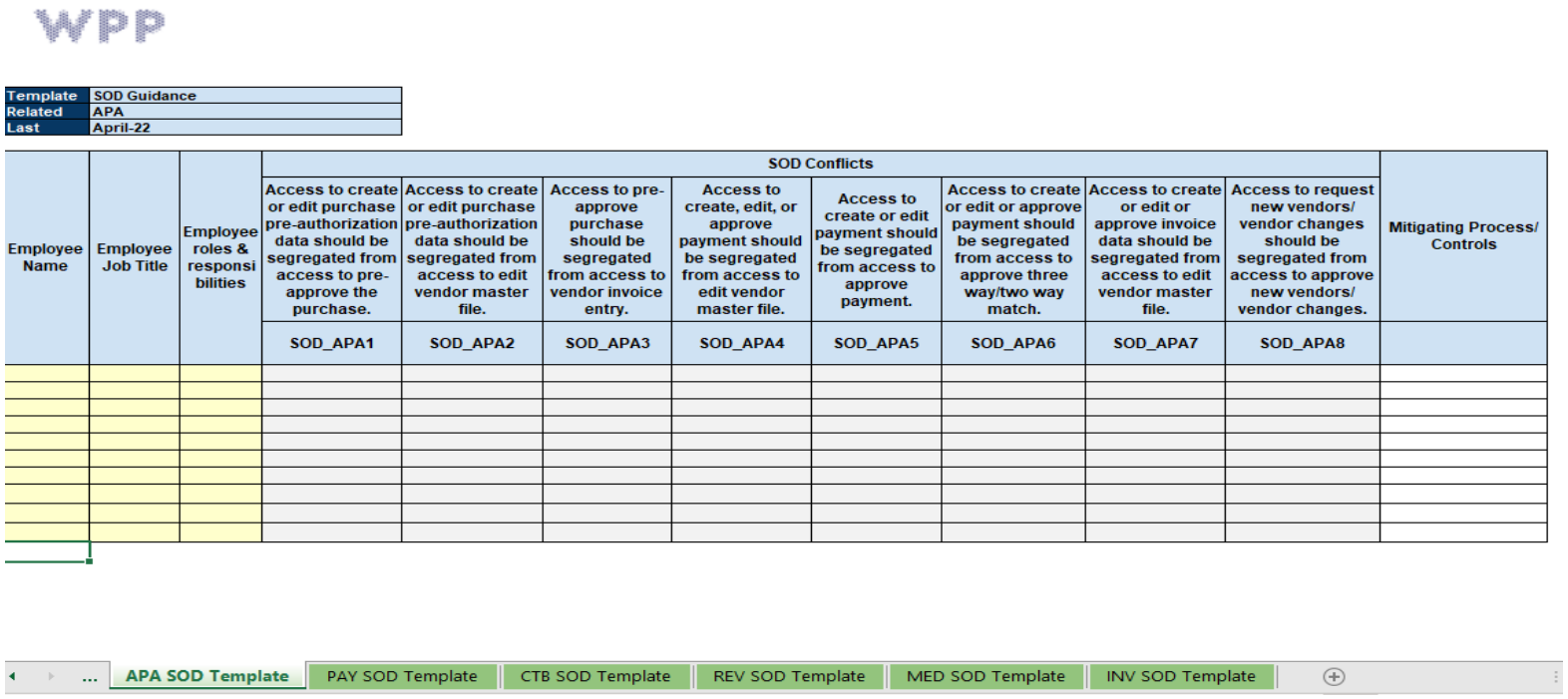
SOD on controls only exists in IT applications.



SEGREGATION OF DUTIES (SOD) ASSESSMENT TEMPLATE

SOD assessment template is available in Risk and Controls Group (RCG)'s page of InsideWPP. The template can be used to document the SOD assessment results.

Link: [WPP Tools and Templates – insideWPP]



Template	SOD Guidance
Related	APA
Last	April-22

Employee Name	Employee Job Title	Employee roles & responsibilities	SOD Conflicts								Mitigating Process/ Controls
			Access to create or edit purchase pre-authorization data should be segregated from access to pre-approve the purchase.	Access to create or edit purchase pre-authorization data should be segregated from access to edit vendor master file.	Access to pre-approve purchase should be segregated from access to vendor invoice entry.	Access to create, edit, or approve payment should be segregated from access to edit vendor master file.	Access to create or edit payment should be segregated from access to approve payment.	Access to create or edit or approve payment should be segregated from access to approve three way/two way match.	Access to create or edit or approve invoice data should be segregated from access to edit vendor master file.	Access to request new vendors/ vendor changes should be segregated from access to approve new vendors/ vendor changes.	
			SOD_APA1	SOD_APA2	SOD_APA3	SOD_APA4	SOD_APA5	SOD_APA6	SOD_APA7	SOD_APA8	

... APA SOD Template | PAY SOD Template | CTB SOD Template | REV SOD Template | MED SOD Template | INV SOD Template

The above screen shot is for accounts payable process. SOD templates for other processes are in different worksheets of the file.

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR PROCURE TO PAY ACTIVITY

CEN controls with SOD conflicts identified on the users' permissions would still be assessed as operating effectively if SOD assessments on the applicable SOD rulesets are performed and effective mitigating process/ controls are implemented.

The following is an example to illustrate how to perform SOD assessment and identify the relevant mitigation process/ control for the SOD conflicts identified on users' permissions in Accounts Payable application.



Employee C
(Procurement Officer)

User Permissions

- Access to approve payment in online banking system
- Access to create new supplier in vendor master file



SOD Conflict Identified
Employee C: SOD_APA4

Mitigating Process / Control

- Remove access to approve payment in online banking system
- Review vendor master file to ensure no inappropriate changes were made to the vendors' master data for the payments approved by employee C

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR PROCURE TO PAY ACTIVITY (EXAMPLE 1)

The following illustrates how to document SOD assessment on employee C's user permission in Accounts Payable application / online banking system and the decision to remove the conflicting access to mitigate the risks arising from the SOD conflict.

HYPOTHETICAL

Example Employee Name	Example Employee Job Title	Example User Permissions	SOD Conflicts								
			SOD_ APA1	SOD_ APA2	SOD_ APA3	SOD_ APA4	SOD_ APA5	SOD_ APA6	SOD_ APA7	SOD_ APA8	Mitigating Process/ Controls
Employee C	Procurement Officer	Create or edit suppliers in ERP and approve payment in online banking system				SOD					Employee C's permission to approve payments in online banking system is not appropriate based on his role as Procurement Officer. This payment approval permission will be revoked. Vendor master data changes report is reviewed. It is confirmed that no changes were made to the vendor master data of payments approved by employee C.

Supporting evidence for the procedures referenced in Mitigating Process / Control should be maintained along with this assessment. The detail will be selected for testing by the auditors.

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR PROCURE TO PAY ACTIVITY

This is another example to illustrate how to perform SOD assessment and identify the relevant mitigation process/ control for the SOD conflicts identified on users' permissions in online banking system.



Employee H (Finance Manager)

User Permissions

- Access to create payment in online banking system
- Access to approve payment in online banking system



SOD Conflict Identified

Employee H: SOD_APA5

Mitigating Process / Control

- Establish detective control by performing an independent review on the list of payments processed by employee H and his user activities log in online banking system (subject to IUC procedures)

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR PROCURE TO PAY ACTIVITY (EXAMPLE 2)

The following illustrates how to document SOD assessment on employee H's user permission in online banking system and the detective control that is in place to mitigate the risks arising from the SOD conflict.

HYPOTHETICAL

Example Employee Name	Example Employee Job Title	Example User Permissions	SOD Conflicts								
			SOD_ APA1	SOD_ APA2	SOD_ APA3	SOD_ APA4	SOD_ APA5	SOD_ APA6	SOD_ APA7	SOD_ APA8	Mitigating Process/ Controls
Employee H	Finance Manager	Create and approve payment in online banking system					SOD				A listing of payments approved by employee H is reviewed by an independent party to ensure the payments were appropriate and supported by proper documentation. Additionally, employee H's user activities log in the online banking system is reviewed on a monthly basis to ensure that no inappropriate payments were processed. Refer to documentation in tab "XX" for the evidence of review and IUC checks performed on the payment listing.

Supporting evidence for the procedures referenced in Mitigating Process / Control should be maintained along with this assessment. The detail will be selected for testing by the auditors.

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR CLOSE THE BOOK ACTIVITY

The following are the examples to illustrate how to perform SOD assessment and identify the relevant mitigation process/ manual or application control for the SOD conflicts identified on users' permissions in General Ledger application.

		User Permission		Mitigating Process / Control
Manual Control	 Employee A (Finance Clerk)	• Access to create and post journal entries (JEs) *Note: Posting of journal entries constitutes approval as there is no 'approve' function due to system limitation.*	 **SOD Conflict Identified** Employee A: SOD_CTB1	• Manual control is in place where another employee acts as the approver. The JEs together with the supporting documents are independently reviewed before posting by employee A.
Application Control	 Employee B (Finance Director)	• Access to create and post journal entries (JEs)	 **SOD Conflict Identified** Employee B: SOD_CTB1	• Application control is in place to prevent employee B from from approving her own JEs. The JEs created by employee B are directed to other approvers for approval in General Ledger application.

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR CLOSE THE BOOK ACTIVITY (EXAMPLE 1)

The following illustrates how to document SOD assessment on employee A's user permission in General Ledger (GL) application and the manual control that is in place to mitigate the risks arising from the SOD conflict.

HYPOTHETICAL

Example Employee Name	Example Employee Job Title	Example User Permission	SOD Conflict	Mitigating Process/ Controls
			Access to create or edit Journal Entries should be segregated from access to approve Journal Entries	
			SOD_CTB1	
Employee A	Finance Clerk	Create and post journal entries (JEs)	SOD	The JEs cannot be entered and posted by two separate employees in GL application due to manpower constraint. Finance Clerk submits the JE listing generated from General Ledger application together with supporting documents to Finance Manager for review and offline approval (subject to IUC procedures). Finance Clerk ensures that the JEs are only posted in the GL application after approvals. Periodically, Finance Manager verifies accuracy and completeness of the JEs posted in GL application to the list of JEs submitted to him/her for approval in previous period. We are comfortable that the manual mitigating control can mitigate the risk arising from the SOD conflict.

SEGREGATION OF DUTIES (SOD) CONFLICT – SOD RULESET FOR CLOSE THE BOOK ACTIVITY (EXAMPLE 2)

The following illustrates how to document SOD assessment on employee B's user permission in General Ledger (GL) application and the application control that is in place to mitigate the risks arising from the SOD conflict.

HYPOTHETICAL

Example Employee Name	Example Employee Job Title	Example User Permission	SOD Conflict	Mitigating Process/ Controls
			Access to create or edit Journal Entries should be segregated from access to approve Journal Entries	
			SOD_CTB1	
Employee B	Finance Director	Create and post journal entries (JEs)	SOD	An application control is configured in GL application to prohibit employee B from posting the JEs created by himself/herself. *Guidance note:* *There are several requirements that need to be met before concluding that the above mitigating process/ control design is effective. Please refer to ICFR Foundations training for more details.*

SUMMARY

Several key take aways about the concept of Segregation of Duties, key steps to perform SOD assessment using SOD rulesets in CEN controls and conclusion/next steps that can be drawn or to be taken based on SOD assessment results.

- Segregation of duties (SOD) is an internal control designed to minimize error and fraud by ensuring that at least two individuals are responsible for the separate parts of any business activity.

- Application control can be configured in IT application to ensure that the same person cannot initiate, approve and record the transactions at the same time to mitigate the risk arising from SOD conflicts.

  - ❖ In Risk Control Matrix, there are several SOD rulesets for key business processes in CEN31 of Control Environment. The SOD rulesets refer to SOD of access control in IT application.

- The initial step for SOD assessment is to determine whether IT application is used to process the transactions. If IT application is not used, document the rationale of the exemption. Otherwise, perform the SOD assessment by referencing to the SOD rulesets in CEN controls and document the assessment results with evidence of approval. If SOD conflicts were identified, design and implement mitigating process/ control to address the SOD conflicts.

- CEN controls with SOD conflicts identified on the users' permissions would still be assessed as operating effectively if SOD assessments on the applicable SOD rulesets are performed and effective mitigating process/ controls are implemented.

KNOWLEDGE CHECK

True or False:

If an SOD conflict on the user's permissions is identified during the SOD assessment, the only way to resolve this conflict is to remove the conflicting user's permission.



An impact assessment on the SOD conflict includes:

- Review if any inappropriate transaction was processed before the SOD conflict was identified.
- Evaluate effectiveness of detective control to minimize risk.
- Consider if SOD conflict can be properly segregated in future.



Supporting documentation for the processes/controls identified to address SOD conflicts do not need to be maintained. The documentation in SOD assessment template is sufficient.



Thank you